

ENTERPRISE SECURITY ASSESSMENT LAB

API Security Evidence Documentation Report

OAuth Request Analysis in Burp Suite Evidence

Professional Portfolio Edition - Authorized API Security Lab Evidence

Field	Details
Test Area	OAuth request analysis
Result Type	OAuth request review
Evidence Report File	18-oauth-lab-burp-request-analysis-evidence-report.pdf
Testing Phase	OAuth Flow Inspection
Tool / Component	Burp Suite Proxy
OWASP / Security Mapping	API2: Broken Authentication / OAuth Misconfiguration
Repository Path	02-api-security/reports/evidence/
Prepared For	GitHub recruiter portfolio documentation

This report documents one API Security evidence row as a standalone professional artifact. It includes the embedded screenshot, what it proves, the methodology context, command/workflow, sanitized output style, risk interpretation, remediation guidance, and publication redaction requirements.

1. Embedded Evidence Screenshot

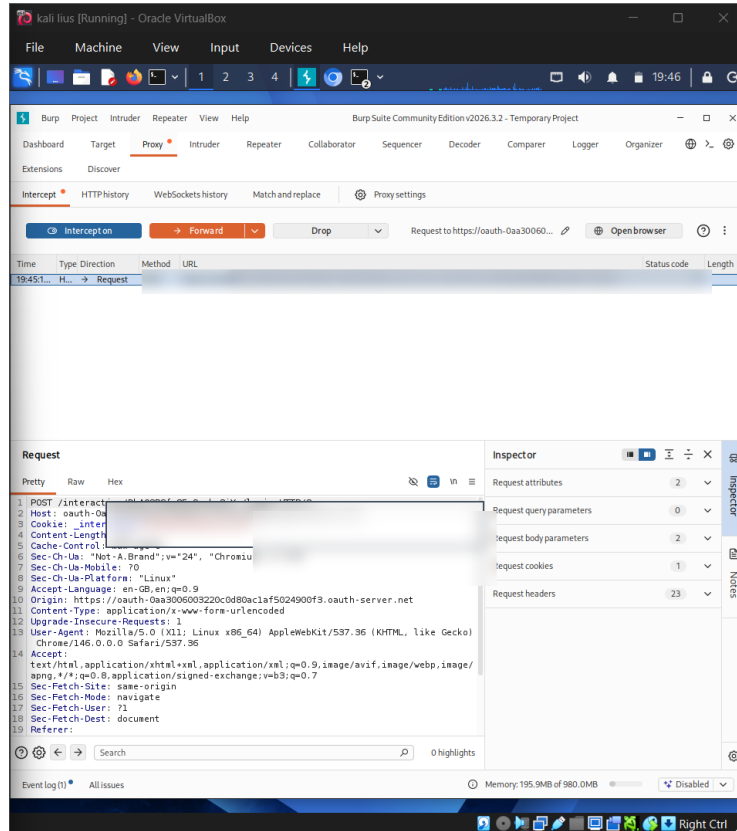


Figure 1 - Embedded screenshot evidence for: OAuth request analysis

What this evidence proves

The evidence shows Burp Suite intercepting an OAuth-related request. Host/cookie/request details are blurred where needed.

Evidence handling note

The screenshot has been prepared for GitHub publication. Sensitive fields such as credentials, tokens, JWTs, cookies, personal data, host values, or other secrets are blurred or represented as redacted values where needed.

2. Assessment Context and Methodology Placement

Area	Value
Testing Phase	OAuth Flow Inspection
Tool / Component	Burp Suite Proxy
Assessment Objective	Capture and inspect OAuth-related requests to review redirect URI, state, scope, response type, cookies, and request parameters.
Result Type	OAuth request review
OWASP / Security Mapping	API2: Broken Authentication / OAuth Misconfiguration

Why this evidence matters

OAuth security depends on strict validation of redirect URI, state, client behavior, scopes, and authorization code/token handling. Request interception helps identify misconfigurations.

Command / workflow used

```
Proxy browser through Burp
Start OAuth flow in lab
Capture authorization / interaction request
Review Host, Cookie, redirect_uri, state, scope, response_type, and client_id
Document risk indicators
```

Sanitized output style

```
POST /interaction/<REDACTED>
Host: <REDACTED_OAUTH_HOST>
Cookie: <REDACTED_COOKIE>
Parameters: state/scope/client information reviewed
```

3. Professional Interpretation

This evidence row should be interpreted as: **OAuth request review**.

OAuth issues can lead to authorization code interception, token leakage, open redirect abuse, CSRF-style login attacks, or excessive scope approval.

Assessor notes

This evidence demonstrates request-level analysis, not necessarily a confirmed OAuth vulnerability.

How a recruiter or reviewer should read this evidence

The value of this evidence is not only the screenshot itself. The value is that it demonstrates a structured API security testing process: controlled lab setup, targeted testing, safe interpretation of results, and clear separation between confirmed vulnerabilities and controls that rejected attack attempts.

Finding interpretation

Where the evidence shows vulnerable behaviour, the report should explain the security impact, the affected object or workflow, and the remediation without publishing sensitive raw values.

4. Risk, Impact, and Remediation Guidance

Risk perspective

OAuth issues can lead to authorization code interception, token leakage, open redirect abuse, CSRF-style login attacks, or excessive scope approval.

Recommended remediation / hardening actions

- Strictly validate `redirect_uri`.
- Use unpredictable state values.
- Use PKCE where appropriate.
- Limit OAuth scopes.
- Protect authorization codes and tokens.
- Avoid leaking tokens in URLs or logs.

Validation guidance after remediation

- Repeat the same test workflow after remediation and compare the response behaviour.
- Confirm that sensitive data is no longer exposed in raw API responses.
- Confirm that unauthorized requests return secure error responses such as 401 or 403 where appropriate.
- Confirm that security controls are enforced server-side, not only in the frontend or client collection.

5. GitHub Publication and Redaction Guidance

Sensitive values to redact before public upload

- OAuth host if private.
- Cookies.
- Authorization codes.
- Tokens.
- Client secrets.
- State values if tied to session.

General API evidence redaction checklist

- Blur JWT access tokens, bearer tokens, OAuth codes, cookies, and authorization headers.
- Blur email addresses, phone numbers, user IDs, vehicle IDs, order IDs, and private object identifiers.
- Do not upload Postman environment files containing live variables or secrets.
- Do not upload raw response exports containing personal data or secret-bearing values.
- Use placeholders such as , , and .

GitHub link format for 02-api-security/README.md

[OAuth request analysis](./reports/evidence/18-oauth-lab-burp-request-analysis-evidence-report.pdf)

Final classification

This PDF is suitable for a public GitHub portfolio only after the embedded screenshot has been reviewed and sensitive values are confirmed blurred or removed.